

REPORT – Gestione dell'incidente relativo alla compromissione del sistema B

Introduzione

Nel presente scenario il sistema **B**, costituito da un database con storage distribuito su più dischi, è stato compromesso da un attaccante esterno che è riuscito a violare la rete aziendale tramite Internet. L'attacco risulta ancora in corso e il team CSIRT è stato attivato per gestire l'incidente.

L'obiettivo primario è contenere la minaccia, impedire ulteriori danni, preservare le evidenze digitali e procedere alla rimozione completa della compromissione, garantendo al contempo la protezione delle informazioni sensibili presenti sui dischi.

Fase di Isolamento

La prima azione da intraprendere in un incidente di questo tipo è l'isolamento del sistema compromesso. L'isolamento ha lo scopo di contenere l'attacco e impedire sia il movimento laterale verso altri sistemi interni sia l'eventuale esfiltrazione di dati verso l'esterno.

Nel caso specifico, il sistema B deve essere immediatamente separato dalla rete. Questo può avvenire tramite disconnessione fisica del cavo di rete, disabilitazione della porta sullo switch o inserimento del server in una VLAN di quarantena. Parallelamente è necessario intervenire a livello firewall per bloccare eventuali comunicazioni in ingresso e in uscita, in particolare verso indirizzi IP sospetti o domini associati a Command and Control (C2).

Prima di procedere a un eventuale spegnimento del sistema, è fondamentale preservare le evidenze digitali. Devono quindi essere raccolti i log di sistema e di rete, effettuato un dump della memoria RAM e creata un'immagine forense dei dischi. Questa attività consente di mantenere traccia dell'accaduto, supportare l'analisi tecnica successiva e, se necessario, fornire elementi utili in ambito legale.

Fase di Rimozione ed Eradicazione

Una volta contenuta la minaccia, si procede alla rimozione della compromissione. La soluzione più sicura e raccomandata consiste in un rebuild completo del sistema. Ciò implica la formattazione totale dei dischi, la reinstallazione del sistema operativo, l'applicazione di tutte le patch di sicurezza disponibili e l'implementazione di misure di hardening.

I dati del database dovranno essere ripristinati esclusivamente da backup verificati e considerati sicuri, ovvero precedenti al momento della compromissione. Questo approccio riduce drasticamente il rischio che eventuali backdoor o meccanismi di persistence rimangano attivi nel sistema.

Contestualmente è necessario procedere alla rotazione di tutte le credenziali potenzialmente compromesse. Ciò include password amministrative, account di servizio, chiavi SSH e

certificati digitali. Questa misura è essenziale per prevenire un nuovo accesso da parte dell'attaccante.

Dopo il ripristino, il sistema dovrà essere monitorato attentamente mediante logging avanzato e strumenti di Endpoint Detection and Response (EDR), al fine di intercettare eventuali comportamenti anomali.

Sanitizzazione dei Dischi: Clear, Purge e Destroy

Prima dello smaltimento o del riutilizzo dei dischi compromessi è necessario procedere alla sanitizzazione dei dati, secondo le buone pratiche internazionali (ad esempio NIST SP 800-88).

Il metodo **Clear** consiste in una cancellazione logica dei dati tramite sovrascrittura o formattazione sicura. Questo metodo è adeguato quando il dispositivo rimane all'interno dell'organizzazione e il livello di sensibilità dei dati non è estremamente elevato.

Il metodo **Purge** rappresenta un livello superiore di sanitizzazione. Include tecniche come il cryptographic erase o il de-gaussing (nel caso di supporti magnetici), rendendo i dati non recuperabili anche tramite strumenti forensi avanzati. È indicato quando il dispositivo potrebbe uscire dal controllo diretto dell'organizzazione o quando i dati sono particolarmente sensibili.

Il metodo **Destroy**, infine, prevede la distruzione fisica del supporto tramite triturazione, frantumazione o incenerimento. Questo approccio garantisce l'impossibilità assoluta di recuperare le informazioni ed è raccomandato per dischi contenenti dati altamente critici o destinati a smaltimento definitivo.

Conclusione

Nel caso analizzato, la gestione corretta dell'incidente prevede un isolamento immediato del sistema B, la preservazione delle evidenze forensi, la rimozione completa della compromissione tramite rebuild del sistema e la rotazione delle credenziali.

Per quanto riguarda i dischi compromessi, la scelta tra Clear, Purge e Destroy dipenderà dalla sensibilità delle informazioni contenute e dalla destinazione finale dei supporti, privilegiando Purge o Destroy in presenza di dati critici.

Un approccio metodico e strutturato consente di contenere l'incidente, ripristinare la sicurezza operativa e ridurre il rischio di future compromissioni.

Venezia, 16/02/2026

Fabio Renna